KARINE OLIVIA PERMANA - 2024071025
KEREN SANDRA SUDARTA - 2024071031

Week 07 Overview — Secure IT Procurement, Vendor Risk, and Cloud

---

Studi Kasus: Penggunaan Layanan Cloud untuk Penyimpanan Data Akademik Mahasiswa

1. Ringkasan Eksekutif (Executive Summary)

Pengadaan teknologi informasi (TI) di lingkungan institusi pendidikan sering kali terjebak pada orientasi biaya murah (cost-driven) dan kecepatan implementasi semata. Dalam studi kasus ini, universitas dihadapkan pada penawaran layanan cloud yang sangat menarik dari segi harga dan kecepatan, namun mengabaikan aspek fundamental keamanan, privasi data, serta tata kelola jangka panjang. Laporan ini bertujuan untuk mengevaluasi risiko dari penawaran tersebut, menetapkan persyaratan keamanan yang wajib dipenuhi, menentukan bukti validasi (evidence), serta merancang strategi pengelolaan akhir masa kontrak (offboarding) guna melindungi integritas data akademik mahasiswa dan reputasi institusi.

2. Analisis Risiko Berdasarkan Kasus (Case Preview Analysis)

Meskipun vendor menawarkan harga terendah dan implementasi tercepat, pemilihan vendor tidak boleh dilakukan hanya berdasarkan kedua faktor tersebut. Mengabaikan aspek keamanan dapat mendatangkan risiko fatal bagi universitas:

- Risiko Lokasi & Kedaulatan Data (Data Sovereignty): Ketidakjelasan lokasi penyimpanan fisik membuka risiko ketidakpatuhan terhadap regulasi privasi data yang berlaku (seperti UU PDP di Indonesia), di mana data warga negara harus dilindungi dalam yurisdiksi hukum tertentu.
- Risiko Rantai Pasok (Subcontractor Risk): Penggunaan subkontraktor tanpa transparansi menghilangkan kendali universitas terhadap siapa saja pihak yang memiliki akses langsung ke data akademik mahasiswa.
- Risiko Keamanan & Insiden: Tanpa standar keamanan yang jelas dan batas waktu pemberitahuan insiden (SLA Incident Notification), universitas akan terlambat

mengetahui jika terjadi kebocoran data, memperparah dampak kerugian, serta menghilangkan bukti pertanggungjawaban hukum.

- Risiko Ketergantungan (Vendor Lock-in): Ketiadaan prosedur pemindahan layanan (offboarding) akan menyulitkan universitas untuk berpindah ke penyedia lain di masa depan, menjebak institusi pada biaya atau layanan yang buruk.

3. Persyaratan Keamanan yang Wajib Dimasukkan ke dalam Kontrak

Guna menutup celah risiko yang ada, kontrak kerja sama dengan vendor cloud wajib memuat klausul-klausul pengaman berikut:

- Standar Enkripsi Data: Wajib menerapkan enkripsi tingkat tinggi, baik saat data diam di server (at rest) maupun saat ditransmisikan (in transit).
- Kewajiban Pelaporan Insiden (Incident Response SLA): Vendor wajib melaporkan segala bentuk insiden keamanan atau pelanggaran data kepada universitas dalam kurun waktu maksimal 24–48 jam sejak insiden terdeteksi.
- Hak Audit (Right to Audit): Universitas (atau auditor independen yang ditunjuk) memiliki hak penuh untuk melakukan inspeksi, peninjauan kepatuhan, dan asesmen keamanan terhadap infrastruktur vendor secara berkala.
- Kepatuhan Privasi dan Regulasi: Vendor harus menjamin kepatuhan penuh terhadap regulasi perlindungan data pribadi yang berlaku.

4. Bukti Kepatuhan (Evidence) yang Harus Diminta dari Vendor

Sebelum kontrak ditandatangani, tim pengadaan universitas wajib meminta bukti autentik berupa:

1. Sertifikasi Keamanan Standar Industri: Contohnya sertifikasi ISO/IEC 27001 (Manajemen Keamanan Informasi) atau SOC 2 Type II yang masih berlaku.
2. Laporan Audit Pihak Ketiga: Hasil laporan Penetration Testing (Pentest) atau Vulnerability Assessment terbaru yang dilakukan oleh lembaga independen.
3. Dokumentasi Arsitektur Keamanan: Penjelasan teknis mengenai isolasi data (multi-tenancy isolation), kontrol akses berbasis peran (RBAC), dan manajemen identitas.

5. Prosedur Pengakhiran Layanan dan Kontrak (Exit Strategy / Offboarding)

Ketika kontrak berakhir atau layanan dihentikan, proses berikut harus berjalan secara pasti dan terdokumentasi:

- Pengembalian Data (Data Return): Seluruh data akademik universitas wajib dikembalikan secara utuh dalam format standar yang dapat dibaca dan digunakan oleh sistem lain.
- Penghapusan Aman (Secure Data Erasure): Vendor wajib menghapus seluruh salinan data universitas dari server aktif, penyimpanan sekunder, maupun cadangan (backup) secara permanen sesuai standar pemusnahan data internasional (misalnya DoD 5220.22-M).
- Dukungan Transisi (Transition Support): Vendor wajib kooperatif dalam membantu proses migrasi data ke penyedia layanan baru tanpa mengenakan biaya tersembunyi atau menciptakan hambatan teknis.

6. Kesimpulan dan Rekomendasi

Prinsip Utama: "Risiko keamanan harus dinilai sebelum kontrak ditandatangani, bukan setelah insiden terjadi."

Rekomendasi untuk Universitas:

1. Tunda Penandatanganan Kontrak: Jangan terburu-buru menyetujui penawaran vendor sebelum seluruh daftar periksa keamanan (security checklist) terpenuhi.
2. Libatkan Tim TI dan Hukum: Proses pengadaan harus melibatkan unit keamanan informasi dan biro hukum universitas untuk menelaah klausul kontrak secara komprehensif.
3. Gunakan Total Cost of Ownership (TCO): Evaluasi biaya jangka panjang (termasuk potensi kerugian akibat kebocoran data), bukan sekadar melihat harga awal yang murah.

Laporan ini disusun sebagai bagian dari pemenuhan materi pembelajaran Week 07: Secure IT Procurement, Vendor Risk, and Cloud Contracts.